Design Analysis Report

System Architecture Blueprint: SecureShare – A Secure File Sharing System

Document ID: ENG-2026-SSH **Status:** Draft for Review **Source:** SecureShare SRS v1.0 (IEEE 830-1998)
Author: Principal Software Architect **Date:** November 2026

1. Executive Summary

This report outlines the structural design, multi-tier architectural breakdown, and component analysis for SecureShare, a web-based platform for encrypted file storage, controlled sharing, and auditable collaboration. The architecture addresses the requirements in the SRS around zero-trust file protection, granular and revocable access control, tamper-evident audit logging, and secure integration with external key-management, malware-scanning, identity, and messaging services.

2. Architectural Layer Analysis

The system adheres to a strict **Four-Layer Component Architecture**, separating the client, stateless application services, isolated security services, and data storage so that the application and storage tiers can scale horizontally and independently.

2.1 Layer 1: Presentation & Client UI Layer

- **Web Application:** A responsive single-page application (React or Vue) providing dashboard, file browser, sharing, and account-settings views. Uses the Web Crypto API for client-side encryption and decryption.
- **Admin Console:** A role-separated back-office interface for user provisioning, storage quotas, sharing policy, and audit-log review. Optional iOS/Android apps expose a subset of upload, download, and share functions.

2.2 Layer 2: API & Application Layer (Stateless REST Services)

- **Authentication Component:** Handles registration, email verification, MFA (TOTP/SMS), SAML 2.0 / OAuth 2.0 SSO, account lockout (5 failures → 15 min), session management, and RBAC enforced on every endpoint.
- **Sharing & Access Service:** Manages direct user shares and signed, time-limited links (expiry, password, download cap, domain restriction); validates permissions before releasing keys or presigned URLs; supports immediate revocation.
- **File Management Service:** Orchestrates uploads, versioning, trash/recovery, folders, tags, and search, deployed behind a load balancer and web application firewall.

2.3 Layer 3: Domain & Security Services Layer

- **Key Management Service (KMS):** Generates, rotates, and releases AES-256 keys; keys are never stored with the encrypted data.
- **Malware Scanning Service:** Scans every upload asynchronously and quarantines infected files before they reach any recipient.
- **Audit-Log Service:** Captures an immutable, timestamped record of every login, upload, download, share, permission change, and deletion.

2.4 Layer 4: Data & Infrastructure Layer

- **Metadata Database:** PostgreSQL cluster holding users, files, versions, folders, permissions, and audit records; Redis provides session and rate-limit caching.
- **Object Storage:** S3-compatible store for encrypted file blobs, with automated backup and replication across at least two availability zones.
- **Notification Provider:** External email/SMS transactional API for verification, MFA codes, share invitations, and expiring-link alerts.

3. Component Interface Matrix

The matrix below captures the dependency paths, communication protocols, and expected interaction models across core application boundaries.

Source Component	Target	Interface Protocol	Design Constraint
Web / Mobile Client	API Layer	HTTPS (TLS 1.2+) / JSON REST	Sessions expire after 30 min inactivity
Web / Mobile Client	Object Storage	Presigned URL (S3 API)	Encrypted blob transferred directly; time-limited URL
Web Client	API Layer (events)	WebSocket / SSE	Secured under the same TLS session
API Layer	Identity Provider	SAML 2.0 / OAuth 2.0	SSO only where enabled by an administrator
API Layer	KMS	REST API	Keys rotated automatically; never co-located with data
API Layer	Malware Scanner	REST (asynchronous)	File unavailable until scan returns clean
API Layer	Email / SMS Provider	Transactional API	Rate-limited; used for MFA and alerts
API Layer	PostgreSQL / Redis	SQL / cache protocol	Audit entries are append-only and tamper-evident

4. Key Structural Attributes & Security

- **Data Security:** All file content must be encrypted with AES-256 at rest and TLS 1.2+ in transit, with client-side encryption where the browser supports it. Passwords are hashed with Argon2 or bcrypt using a unique per-user salt.
- **Access Control:** RBAC and least privilege are enforced on every API endpoint; rate limiting protects authentication and API endpoints; the design targets resistance to the OWASP Top 10.
- **Performance & Concurrency:** The platform must support at least 10,000 concurrent authenticated users per region; 95% of transfers up to 100 MB complete within 10 seconds; metadata operations stay under 2 seconds at the 95th percentile.
- **Availability & Fault Tolerance:** 99.9% monthly uptime, redundant storage across two or more availability zones, RPO of 15 minutes and RTO of 4 hours. Loosely coupled, independently deployable services prevent a single-component slowdown from disrupting the rest of the system.
- **Compliance:** GDPR Articles 15–17 (access, export, erasure), configurable data-residency regions, and audit logs retained for at least 12 months.
- **Open Items:** Final malware-scanning provider, launch data-residency regions, and inclusion of desktop sync clients remain to be decided.